

TOPEC 사내 법률검토 AI 시스템 — 관리자(시스템) 사용 매뉴얼

버전 1.0 · 2026-07-30 · 대상: 시스템관리자(SYSTEM_ADMIN) 및 운영 담당자

이 문서는 일반 임직원용 EMPLOYEE_USER_MANUAL.md의 기능을 이미 알고 있다는 전제로, 관리자 전용 화면과 운영 업무만 다룹니다. 서버 접속정보 · API 키 등 민감한 인프라 정보는 이 문서에 포함하지 않습니다(별도 보안 채널로 관리).

1. 권한 체계 개요

시스템은 역할 기반 접근제어(RBAC)를 사용하며, 한 사용자가 여러 역할을 동시에 가질 수 있습니다.

역할	한글 표기	설명
USER	일반사용자	기본 역할. 대시보드 · 내 문서 · 계약서 업로드
LITIGATION_ACCESS	소송 · 분쟁 사건 담당	"소송 · 분쟁 사건" 메뉴 접근
LEGAL_REVIEWER	법무담당자	"법무 검토함"에서 배정된 검토 처리, 소송 · 분쟁 사건 메뉴도 자동 포함
DEPARTMENT_ADMIN	부서관리자	같은 부서 소속 사용자의 문서 열람 가능, 소송 · 분쟁 사건 메뉴 포함
EXECUTIVE	경영진	극비를 제외한 모든 문서 열람 가능(요약 수준), 소송 · 분쟁 사건 메뉴 포함
SYSTEM_ADMIN	시스템관리자	전체 시스템 관리자 화면 접근, 모든 문서 열람 · 삭제, 사용자 관리

1.1 시스템 기본 원칙

- "본인이 올린 문서는 본인만 볼 수 있다"가 기본 규칙입니다. 위 표의 예외 역할만 추가로 열람할 수 있습니다.
- SYSTEM_ADMIN은 모든 예외를 관통하는 최상위 권한입니다 — 전체 사용자 · 문서 · 로그에 접근 가능합니다.
- 문서 삭제는 "문서를 올린 본인" 또는 SYSTEM_ADMIN만 가능합니다(부서관리자 · 경영진 · 법무담당자는 열람은 가능해도 삭제는 불가).

2. 관리자 화면 접근

SYSTEM_ADMIN 역할을 가진 계정으로 로그인하면 좌측 사이드바에 아래 3개 메뉴가 추가로 나타납니다.

- 관리자 (/admin) — 시스템 현황, 사용자 관리, 가입 승인
- 리소스 모니터링 (/admin/monitoring) — 저장공간 · AI 사용량 실시간 확인
- 로그 기록 (/admin/logs) — 감사 로그, 로그인 시도 이력

3. 관리자 홈 (/admin)

3.1 시스템 현황 탭

- 통계 카드: 전체 사용자 / 활성 사용자 / 전체 계약서 / 이번 달 등록 / 법무검토 요청 대기 / 법무검토 완료 / 분석 실패 건수 / AI 호출 건수
- AI 토큰 사용량: 전체 사용자 합산 입력 · 출력 토큰 수
- 시스템 연동 상태: Database / Redis / Object Storage / AI Provider(현재 사용 중인 Provider명과 설정 여부, Mock 모드 여부) / 공공데이터포털(법령) 연동 여부 / 국가법령정보 LINK(판례) 연동 여부를 초록/빨강 점으로 표시. 빨간 점이 있으면 해당 기능이 제한됩니다.

3.2 사용자 관리 탭

사용자 직접 등록

관리자가 사번 · 이메일 · 이름 · 부서 · 역할을 입력하고 "사용자 등록"을 누르면 계정이 즉시 생성되며, 화면에 임시 비밀번호가 한 번만 표시됩니다. 이 창을 닫으면 다시 조회할 수 없으므로 안전한 방법(직접 대면, 사내 메신저 등)으로 본인에게 전달하세요. 해당 사용자는 최초 로그인 시 반드시 비밀번호를 변경해야 합니다.

이 방식으로 만든 계정은 이메일 인증 · 관리자 승인 절차 없이 곧바로 사용 가능한 상태(APPROVED)로 생성됩니다. 자가 회원가입 (§ 4)과는 다른 경로입니다.

사용자 목록

사번/이름/이메일/휴대폰/부서/역할/상태를 확인할 수 있고, 활성화 · 비활성화 토글로 계정을 즉시 잠글 수 있습니다(퇴사자 처리 등에 사용). 상태 컬럼은 다음 중 하나로 표시됩니다.

표시	의미
이메일 인증 대기	자가 회원가입 후 아직 이메일 인증 링크를 클릭하지 않음
관리자 승인 대기	이메일 인증은 완료, 관리자 승인만 남음 → § 3.3에서 처리
반려됨	관리자가 가입을 반려함
활성 / 비활성	정상 사용 가능 / 관리자가 비활성화함

사용자별 세부 권한 수정

가입 시점이나 승인 시점에 부여한 권한이 이후에 바뀌어야 하는 경우(부서 이동, 소송 대응 투입, 법무담당자 지정 등), 사용자 목록에서 언제든지 역할을 다시 조정할 수 있습니다.

1. 역할을 바꿀 사용자 행에서 "권한 수정"을 클릭합니다.
2. 역할 칸이 체크박스 목록(일반사용자 · 소송 · 분쟁 사건 담당 · 법무담당자 · 부서관리자 · 경영진 · 시스템관리자)으로 바뀝니다. 부여할 권한은 체크하고, 회수할 권한은 체크 해제합니다.
3. "저장"을 누르면 즉시 반영되고, "취소"를 누르면 변경 없이 원래 화면으로 돌아갑니다.

체크박스 상태는 저장 시 그 사용자의 전체 역할을 그대로 교체합니다(추가만 되는 것이 아니라 해제한 권한은 실제로 회수됩니다). 본인 계정의 "시스템관리자" 권한을 실수로 해제하면 관리자 화면 접근 권한을 스스로 잃을 수 있으니 주의하세요.

3.3 가입 승인 탭

자가 회원가입 (§ 4) 신청 중 이메일 인증까지 마친 사용자가 이 목록에 나타납니다(탭 이름 옆 숫자가 대기 건수).

각 신청 건에서:

- 이름 · 사번 · 이메일 · 휴대폰 번호 확인
- 일반직원 기본 권한은 항상 자동 부여됩니다(체크 해제 불가 — 대시보드 · 내 문서 · 계약서 업로드)
- 필요에 따라 "소송 · 분쟁 사건 접근 권한", "법무 검토함 접근 권한(법무담당자)" 체크박스를 선택
- 승인을 누르면 선택한 권한이 함께 부여되고 계정이 즉시 로그인 가능해집니다.
- 반려를 누르면 해당 신청은 거부 처리됩니다(계정은 비활성 상태로 남으며 로그인 불가).

4. 자가 회원가입 승인 흐름 상세

일반 임직원이 로그인 화면의 "회원가입"으로 직접 신청하는 경로는 3단계입니다.

1. 가입 신청 — 사용자 ID/이름/휴대폰/회사이메일/비밀번호 입력 → `PENDING_EMAIL_VERIFICATION` 상태로 계정 생성, 인증 메일 발송
2. 이메일 인증 — 사용자가 메일의 링크를 클릭 → `PENDING_ADMIN_APPROVAL` 상태로 전환 (이 시점부터 § 3.3 "가입 승인" 탭에 노출)
3. 관리자 승인 — 관리자가 § 3.3에서 승인 → `APPROVED` 상태로 전환, 로그인 가능

회사 이메일 도메인 제한(`topec.co.kr` 등)이 걸려 있어 사내 이메일이 아니면 가입 신청 자체가 거부됩니다. 도메인 정책 변경이 필요하면 개발팀에 `SIGNUP_ALLOWED_EMAIL_DOMAINS` 환경변수 조정을 요청하세요.

5. 리소스 모니터링 (/admin/monitoring)

15초마다 자동 갱신됩니다.

- 저장공간 사용량: 전체 업로드 문서 용량 합계를 게이지로 표시. 하단에서 임계치(GB)를 직접 입력해 변경할 수 있습니다(기본값 100GB). 임계치에 가까워지면 서버 디스크 증설 또는 오래된 문서 정리를 검토하세요.
- AI 토큰 사용량: 오늘 / 이번 달 / 전체 누적 호출 건수와 입력 · 출력 토큰 수, Provider(Claude/Gemini/OpenAI 등)별 세부 내역.

6. 로그 기록 (/admin/logs)

6.1 감사 로그 탭

문서 열람/업로드/수정/삭제, 회원가입/승인/반려, 로그인 실패 등 시스템 내 주요 행위 기록입니다. 행위 종류(action)와 성공/실패 조건으로 필터링할 수 있고, 각 행에는 수행한 사용자 이름이 함께 표시됩니다.

6.2 로그인 시도 이력 탭

성공/실패를 포함한 모든 로그인 시도 이력입니다. 특정 계정이 반복적으로 로그인에 실패하고 있다면(무차별 대입 공격 의심 등) 여기서 확인할 수 있습니다.

7. 문서 삭제 권한

SYSTEM_ADMIN은 본인이 올리지 않은 문서도 삭제할 수 있는 유일한 역할입니다. 아래 세 곳 어디서든 삭제 버튼이 보입니다.

- 문서 상세화면 우측 상단 "문서 삭제"
- "내 문서" 목록의 각 행 (다만 목록 자체는 본인 문서 위주로 노출되며, 시스템관리자는 전체 문서를 봅니다)
- 소송·분쟁 사건 상세화면의 "문서 목록" 탭 각 행

퇴사자가 올린 부적절한 문서, 테스트 데이터, 중복 업로드 등을 정리할 때 사용하세요. 삭제는 되돌릴 수 없습니다.

8. 문서 분석 실패 대응 지원

일반 사용자가 "분석 실패" 문의를 해오면, 문서 상세화면 상단의 빨간 배너에 표시된 실제 실패 사유를 함께 확인하세요. 자주 발생하는 원인:

- "CONFIDENTIAL 등급 문서는 내부망 AI 설정이 없으면 분석할 수 없습니다" → 의도된 보안정책입니다. 문서가 실제로 극비 수준이 아니라면, 관리자 권한으로 문서 상세화면에서 보안등급을 낮추고 "변경 후 재분석"을 눌러 해결할 수 있습니다. 실제로 극비 문서라면 내부망 AI(LocalModelProvider) 연동 전까지는 분석이 제한되는 것이 정상입니다.
- 그 외 오류(AI 응답 형식 오류, 일시적 장애 등) → "재분석 시도" 버튼으로 재시도. 반복 실패 시 개발팀에 감사 로그(§ 6.1)와 함께 전달하세요.

9. 법무검토 배정 관리

법무검토 요청은 담당자가 "법무 검토함"에서 스스로 "내가 담당"을 눌러 배정받는 구조입니다(관리자가 강제로 배정하는 화면은 현재 없음). 특정 담당자에게 반드시 배정해야 하는 사안이 있다면 사내 메신저 등으로 직접 안내하세요.

10. AI Provider / 정부기관 연동 현황 (참고)

시스템 현황 탭(§ 3.1)의 "시스템 연동 상태"에서 아래 연동의 정상 여부를 한눈에 확인할 수 있습니다.

- AI Provider: 기본은 Anthropic Claude이며, Google Gemini를 교차검토용 보조 AI로 함께 사용합니다. 극비 등급 문서는 내부망 AI 없이는 어떤 외부 Provider도 사용하지 않습니다(§ 8 참고).
- 공공데이터포털(법령) / 국가법령정보 LINK(판례): 실시간 법령·판례 검색에 사용됩니다. 빨간 점으로 표시되면 서비스키/인증정보가 만료되었거나 미설정된 것이므로 개발팀에 갱신을 요청하세요.

이 항목들의 API 키 · 환경변수 등 기술적인 설정 방법은 docs/MASTER_REBUILD_GUIDE.md(§ 6 환경변수 레퍼런스, § 7 외부 서비스 계정 체크리스트)를 참고하세요. 실제 키 값은 운영 서버의 .env 파일에서만 관리되며 이 문서에는 포함되어 있지 않습니다.

11. 배포/운영 참고

서버 재배포, Docker 명령어, 접속정보(SSH 키 · 서버 IP) 등 인프라 운영에 관한 절차는 보안상 이 매뉴얼에 포함하지 않습니다. 해당 내용은 docs/MASTER_REBUILD_GUIDE.md와 docs/IMPLEMENTATION_STATUS.md(개발팀/운영팀 전용 기술 문서)를 참고하거나 개발 담당자에게 문의하세요.

12. 보안 정책 요약

- 문서 접근: 본인 문서만 조회 가능(예외: 관리자/같은 부서 부서관리자/배정된 법무담당자/경영진(극비 제외))이 원칙입니다.
- 문서 삭제: 본인 또는 시스템관리자만 가능합니다.
- 극비(CONFIDENTIAL) 등급: 내부망 AI 없이는 어떤 외부 AI 서비스로도 전송하지 않습니다. 예외 없음.
- 계정 잠금: 로그인 5회 연속 실패 시 자동 잠금됩니다.
- 감사 로그: 로그인 실패를 포함해 시스템 내 주요 행위가 모두 기록되며 삭제되지 않습니다.

13. 문제 해결 가이드 (자주 받는 문의)

문의 내용	확인/조치
로그인이 안 돼요	사용자 관리 탭에서 상태 확인 → "이메일 인증 대기"면 본인이 메일 확인 필요, "관리자 승인 대기"면 § 3.3에서 승인, "비활성"이면 활성화 필요
가입했는데 승인 요청이 안 보여요	아직 이메일 인증을 안 했을 가능성이 높음(§ 4) — 본인에게 메일함 확인 요청
특정 메뉴가 안 보여요	사용자 관리 탭에서 역할 확인 — 소송 · 분쟁 사건/법무 검토함은 별도 권한 필요(§ 3.3에서 부여, 또는 § 3.2에서 역할 추가는 재가입 승인이 아닌 재등록 필요 시 개발팀 문의)
문서 분석이 계속 실패해요	§ 8 참고
인증 메일이 안 와요	리소스 모니터링(§ 5)에서 AI/시스템 상태는 정상인지 확인 후에도 반복되면 메일 발송 연동(Resend) 문제일 수 있음 — 개발팀 문의
저장공간이 부족하다는 안내를 봤어요	리소스 모니터링(§ 5)에서 사용량 확인, 임계치 조정 또는 불필요한 문서 삭제(§ 7) 안내